

JWT authentication bypass via unverified signature

Topic: JWT | Difficulty: Apprentice

Description

The application accepts JSON Web Tokens without verifying their cryptographic signature. An attacker can decode the JWT, modify the payload to claim any user identity (e.g., administrator), re-encode it with an arbitrary or unchanged signature, and the server accepts the forged token granting elevated access.

Steps to Exploit

1. Log in and capture the session JWT from the response cookies.
2. Decode the JWT in Burp Suite's JWT Editor tab or at jwt.io.
3. In the payload section change the 'sub' claim to 'administrator'.
4. Click 'Sign' and select 'Don't modify header' / keep existing signature.
5. Replace the JWT in the Cookie header of a new request.
6. Navigate to /admin and observe that administrative access is granted.

Proof of Concept

Original JWT Payload:

```
{"sub": "wiener", "iat": 1700000000}
```

Forged JWT Payload:

```
{"sub": "administrator", "iat": 1700000000}
```

Result:

Server accepts the modified token and grants admin privileges without valid signature.

Impact

- Horizontal and vertical privilege escalation to any user account.
- Full administrative access to the application.
- Bypass of all authorization controls based on JWT claims.
- Complete application compromise potential.

Mitigation / Remediation

1. Always verify JWT signatures server-side before trusting any claim.
2. Use a well-maintained JWT library that enforces signature validation by default.
3. Reject tokens with missing, empty, or invalid signatures immediately.
4. Implement JWT expiration (exp) and issued-at (iat) claim validation.

CVSS Score

CVSS v3.1: 9.1 (Critical)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

CVSS Justification

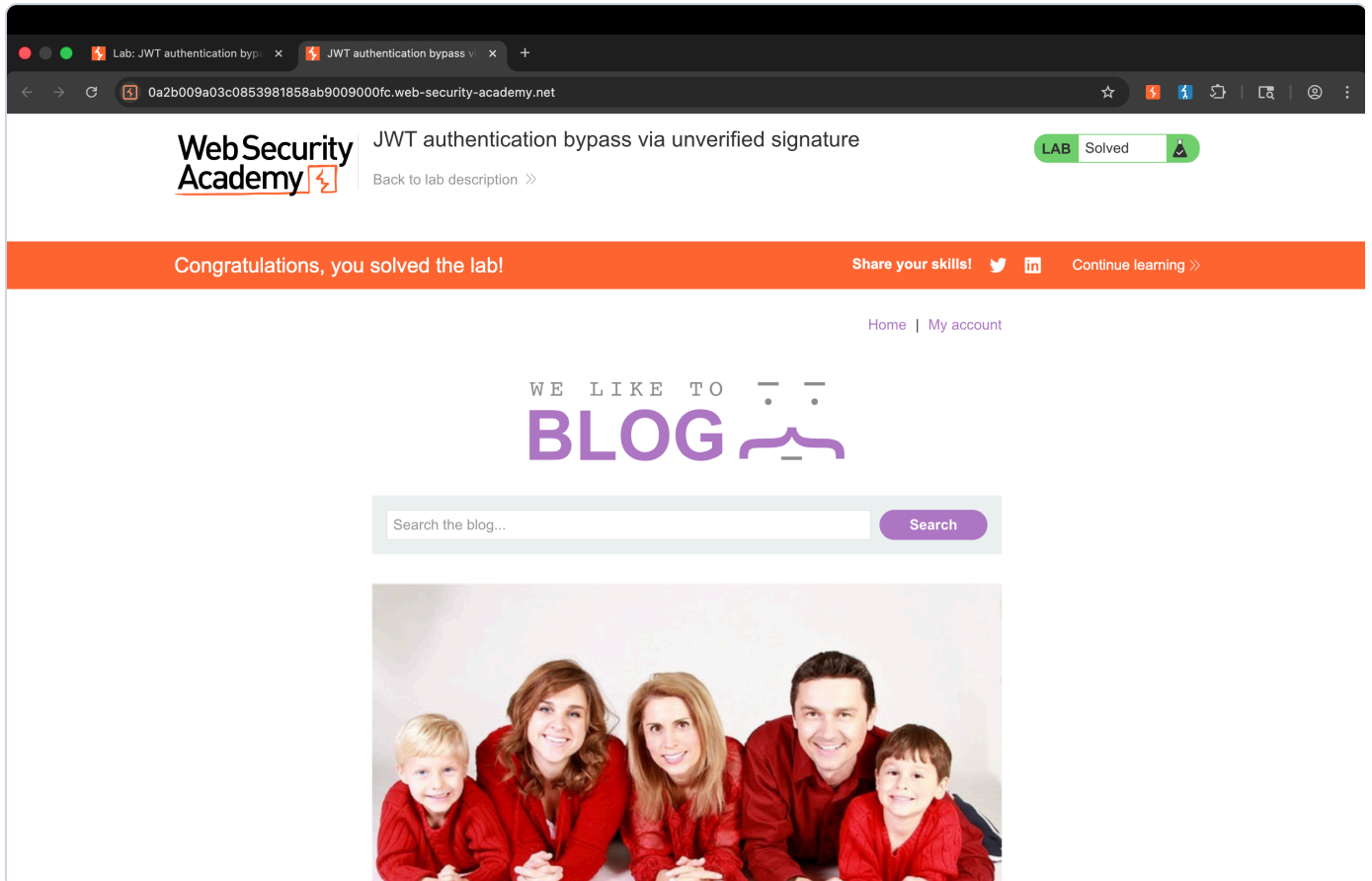
- Attack Vector: Network - token modification via client-side tools.
- Attack Complexity: Low - simple base64 decode and re-encode.
- Privileges Required: None - any session token can be forged.
- User Interaction: None.
- Confidentiality / Integrity: High - full privilege escalation achieved.
- Availability: None.

JWT Unverified Signature

Proof of Concept — Exploitation Evidence

Payload / exploit steps are documented in the **Proof of Concept** section of this writeup (above). Screenshot evidence of successful exploitation is shown below.

Lab Solved Confirmation



PortSwigger lab status changed to "Solved" after exploitation.